

# VYBE — Security Rules

베타 버전 기준 · v1 · Firestore + Storage

---

## Firestore Security Rules

**users/{uid}**

읽기

본인 UID와 일치할 때만 가능

```
request.auth.uid == uid
```

쓰기

본인 UID와 일치할 때만 가능 — uid / provider / createdAt 필드는 수정 불가

```
!request.resource.data.diff(resource.data).affectedKeys().hasAny(['uid', 'provider', 'createdAt'])
```

**clubs/{clubId}**

읽기

누구나 가능 (비로그인 포함) — isActive == true 인 문서만

```
resource.data.isActive == true
```

쓰기

어드민만 가능

```
request.auth.token.admin == true
```

**clubs/{clubId}/info   ·   clubs/{clubId}/menus/{menuId}**

읽기

누구나 가능 (비로그인 포함)

쓰기

어드민만 가능

```
request.auth.token.admin == true
```

**clubs/{clubId}/reviews/{reviewId}**

읽기

누구나 가능 (비로그인 포함)

생성

로그인한 유저만 가능 — userId 필드가 본인 UID와 일치해야 함

```
request.auth != null && request.resource.data.userId == request.auth.uid
```

수정

작성자 본인만 가능 — userId / clubId / createdAt 필드 수정 불가

```
resource.data.userId == request.auth.uid
```

삭제

작성자 본인 또는 어드민만 가능

```
resource.data.userId == request.auth.uid || request.auth.token.admin == true
```

**favorites/{favoriteId}**

읽기

본인 userId와 일치할 때만 가능

```
resource.data.userId == request.auth.uid
```

생성

로그인한 유저만 가능 — userId 필드가 본인 UID와 일치해야 함

```
request.auth != null && request.resource.data.userId == request.auth.uid
```

삭제

본인 userId와 일치할 때만 가능

```
resource.data.userId == request.auth.uid
```

**users/{uid}/searchHistory/{historyId}**

|    |                                                                       |
|----|-----------------------------------------------------------------------|
| 읽기 | 본인 UID와 일치할 때만 가능<br><code>request.auth.uid == uid</code>             |
| 생성 | 본인 UID와 일치할 때만 가능<br><code>request.auth.uid == uid</code>             |
| 삭제 | 본인 UID와 일치할 때만 가능 (검색어 개별 삭제)<br><code>request.auth.uid == uid</code> |

## Storage Security Rules

**clubs/\*\***

|    |                                                                                                                                                                                                        |
|----|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 읽기 | 누구나 가능                                                                                                                                                                                                 |
| 쓰기 | 어드민만 가능 — 파일 크기 10MB 이하, 이미지 형식만 허용<br><code>request.auth.token.admin == true &amp;&amp; request.resource.size &lt; 10 * 1024 * 1024 &amp;&amp; request.resource.contentType.matches('image/*')</code> |

**reviews/{clubId}/{reviewId}/\*\***

|    |                                                                                                                                                                                                |
|----|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 읽기 | 누구나 가능                                                                                                                                                                                         |
| 쓰기 | 로그인한 유저만 가능 — 파일 크기 10MB 이하, 이미지 형식만 허용<br><code>request.auth != null &amp;&amp; request.resource.size &lt; 10 * 1024 * 1024 &amp;&amp; request.resource.contentType.matches('image/*')</code> |

**users/{uid}/\*\***

|    |                                                                                                                                                                                                       |
|----|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 읽기 | 누구나 가능                                                                                                                                                                                                |
| 쓰기 | 본인 UID와 일치할 때만 가능 — 파일 크기 5MB 이하, 이미지 형식만 허용<br><code>request.auth.uid == uid &amp;&amp; request.resource.size &lt; 5 * 1024 * 1024 &amp;&amp; request.resource.contentType.matches('image/*')</code> |

## 어드민 권한 설정 방법

Firebase Admin SDK로 특정 UID에 Custom Claim을 부여하면 `request.auth.token.admin == true` 조건으로 Rules에서 어드민 여부를 확인할 수 있어요.

## 예시 코드 (Admin SDK)

```
admin.auth().setCustomUserClaims(uid, { admin: true })
```